CYBERSECURITY TECHNICAL REPORT

LEGAL SCOPE, ASSET INVENTORY & THREAT MODEL

Prepared by	JAYASURYA R
Project	Authorized Security Lab Assessment
Document type	Cybersecurity Technical Report
Purpose	Internship Work Submission
Status	Draft — Authorization Pending

Submission note: *This report documents a proposed assessment plan. It does not confirm that written authorization has been granted or that the laboratory has been tested.*

1. Executive Summary

This document establishes the legal scope, asset inventory, and threat-modeling framework for an authorized security testing laboratory. It identifies intended targets, system boundaries, potential security risks, and safeguards for responsible assessment.

The proposed scope contains a local training web application and a deliberately vulnerable virtual machine. Details that have not been confirmed from the actual lab are explicitly marked **To be verified** rather than guessed.

All active testing must remain within the approved scope and must not begin until the responsible lab owner provides written authorization.

2. Objectives

• Establish clear legal and technical testing boundaries.

• Identify and document the authorized laboratory assets.

• Determine trust boundaries, identities, data classifications, and attack surfaces.

• Identify potential threats using STRIDE.

• Prioritize mitigations by risk and potential impact.

• Define rules of engagement, evidence handling, escalation, and stop conditions.

3. Legal Scope and Authorization

3.1 Authorized Assets

Asset ID	Asset	Environment	Address
LAB-01	Local training web application	Isolated localhost (listed; confirm)	http://127.0.0.1:8080
LAB-02	Deliberately vulnerable virtual machine	Private host-only network (listed; confirm)	192.168.56.20

These assets are listed in the supplied laboratory inventory. Availability, ownership, isolation, and configuration must be confirmed before testing.

3.2 Scope Limitations

• Denial-of-service, load, and stress testing.

• Scanning third-party, public-facing, or production systems.

• Establishing persistence or executing destructive payloads.

• Credential reuse, password spraying, or unauthorized privilege changes.

• Uncontrolled extraction of sensitive information.

• Social engineering, malware deployment, or unauthorized outbound network traffic.

• Any activity outside the approved scope.

3.3 Authorization Record

Field	Current record
Assessor	JAYASURYA R
Approval date	Pending confirmation by the lab owner
Emergency contact	Pending confirmation by the lab owner
Approved test window	Pending agreement; record start time, end time, and time zone

Complete and obtain approval for the authorization fields before any active testing begins.

4. Asset Inventory

This table consolidates the known inventory and identifies missing technical facts. “To be verified” is intentional: confirm these values from the actual lab rather than assuming them.

Attribute	LAB-01 — Training web app	LAB-02 — Vulnerable VM
Asset / purpose	Local training web application; intended for controlled web security practice.	Deliberately vulnerable virtual machine; intended for controlled host/service security practice.
Owner / custodian	RabTech lab (listed; confirm with lab owner).	RabTech lab (listed; confirm with lab owner).
Environment	Isolated localhost (listed; verify actual host and isolation).	Private host-only network (listed; verify hypervisor and network isolation).
Address / identifier	http://127.0.0.1:8080 (listed; confirm service responds locally).	192.168.56.20 (listed; confirm VM address and reachability from approved host only).
Operating system	To be verified.	To be verified.
Application / software version	Application framework, version, and build: To be verified.	Guest OS, installed software, and versions: To be verified.
Listening services / ports	To be verified; document only observed services.	To be verified; document only observed services.
Authentication / identities	Login method, roles, and test accounts: To be verified. Use only owner-approved accounts.	Accounts, privilege levels, and approved test credentials: To be verified.
Data handled / storage	Data types, database, file storage, and test-data status: To be verified.	Files, services, and any stored data: To be verified.
Network connections	Expected local-only access; verify listening interface, routes, and outbound connectivity.	Expected host-only network; verify routes, gateway, DNS, and outbound connectivity.
Testing permission	Only after written authorization and confirmation of scope.	Only after written authorization and confirmation of scope.
Excluded actions	No DoS, stress testing, or third-party scanning.	No persistence, destructive changes, or unapproved outbound traffic.
Evidence classification	Confidential training evidence; redact secrets and personal data.	Confidential training evidence; redact secrets and personal data.
Owner contact / emergency escalation	Pending confirmation by the lab owner.	Pending confirmation by the lab owner.

Inventory completion checklist: *Confirm ownership and written approval; record actual OS/software versions and services; document approved identities and data classes; verify network isolation; record test window and emergency contact. Do not fill unknown fields with guesses.*

5. Trust Boundaries and Data Flow

5.1 Logical Components

• Assessor workstation — system used to conduct approved checks and document observations.

• LAB-01 application boundary — local web application and request-handling components.

• LAB-02 virtual-machine boundary — deliberately vulnerable system hosted on a private network.

• Evidence-storage boundary — approved location for reports, screenshots, logs, and assessment notes.

5.2 Proposed Data Flow

The assessor sends approved requests to LAB-01 or interacts with LAB-02. Relevant responses and observations are recorded as assessment evidence. Evidence is stored securely and used to prepare the report.

This is a planning model, not a verified network diagram. Confirm actual connections, routes, interfaces, and data flows against the configured laboratory before testing.

5.3 Security Controls

• Restrict access to approved laboratory assets and approved assessor accounts.

• Verify network isolation and prevent unintended communication with external systems.

• Use only approved test data and accounts; avoid collecting unnecessary sensitive data.

• Protect collected evidence with access controls and redaction.

• Record asset, timestamp, action, observation, and evidence reference for each finding.

• Do not include secrets or confidential information in public documentation.

6. STRIDE Threat Model

The following are preliminary threat hypotheses for review against the real system architecture. They are not confirmed vulnerabilities.

Threat	Potential threat	Recommended mitigation	Priority
Spoofing	Unauthorized impersonation of a legitimate user.	Enforce authentication and validate session handling.	High
Tampering	Unauthorized modification of application data or configuration.	Apply access controls, input validation, and integrity checks.	High
Repudiation	Actions cannot be reliably attributed to an identity.	Maintain protected, timestamped audit logs.	Medium
Information disclosure	Sensitive information becomes accessible to unauthorized users.	Use least privilege, secure storage, and data minimization.	High
Denial of service	Application availability is disrupted.	Use resource limits; disruptive testing is out of scope.	High
Elevation of privilege	A user gains permissions beyond those assigned.	Enforce server-side authorization and least privilege.	High

Priorities should be revised after the architecture, likelihood, impact, and any verified findings are reviewed.

6.1 Abuse Cases

Case 1 — Unauthorized access: A person attempts to access a function without the required permission. Control: enforce server-side authorization.

Case 2 — Data modification: An unauthorized user attempts to change protected data. Controls: input validation, access restrictions, and integrity monitoring.

Case 3 — Sensitive information exposure: Confidential data becomes accessible through an improperly protected endpoint or log. Controls: data minimization, secure storage, and access restrictions.

Case 4 — Boundary violation: Testing activity reaches a system outside the approved environment. Stop immediately and notify the responsible contact.

7. Ranked Mitigation Plan

Priority 1 — Scope and access controls

• Obtain written authorization and confirm the exact assets.

• Agree on the testing window and emergency escalation contact.

• Verify network isolation and access restrictions.

• Confirm stop conditions and how to report an incident.

Priority 2 — High-risk security controls

• Review authentication and authorization controls.

• Validate input handling and data-integrity safeguards.

• Protect sensitive information and assessment evidence.

• Verify network restrictions and outbound traffic controls.

Priority 3 — Monitoring and documentation

• Enable appropriate audit logging.

• Record findings with timestamps and supporting evidence.

• Document remediation recommendations and retest results.

• Reassess risk after corrective actions.

8. Rules of Engagement

8.1 Permitted activities

Following written approval, conduct only controlled, non-destructive checks against the specifically authorized assets during the agreed window.

8.2 Prohibited activities

No denial-of-service attempts, destructive payloads, persistence, unauthorized privilege changes, uncontrolled data extraction, third-party scanning, or unapproved outbound communication.

8.3 Evidence Handling

• Classify evidence as confidential training evidence.

• Store evidence in an access-controlled location.

• Redact passwords, tokens, and unnecessary personal information.

• Record date/time, affected asset, observation, and supporting evidence reference.

• Follow retention and deletion requirements agreed with the lab owner.

• Obtain approval before publishing evidence that may expose sensitive information.

8.4 Escalation and Stop Conditions

Stop testing immediately if any of the following occurs:

• Unexpected service interruption.

• Unexpected exposure of sensitive information.

• A request or connection reaches an out-of-scope system.

• Network isolation is uncertain.

• Unexpected change to system state.

• The approved testing window ends.

• The lab owner or authorized contact asks testing to stop.

Notify the designated emergency contact and document the time, affected asset, observed condition, and actions taken. Do not resume until the responsible owner authorizes it.

9. Findings and Reporting

For each finding, record a unique ID, title, affected asset, severity and rationale, preconditions, safe reproduction summary, evidence reference, impact, recommended remediation, and verification status. Clearly distinguish confirmed findings from theoretical risks.

10. Conclusion

This report provides a structured plan for an authorized lab assessment. The asset inventory now separates listed information from technical details that remain unverified. Written authorization, the approved test window, owner contacts, and actual lab configuration must be confirmed before active testing.

Prepared by: *JAYASURYA R*
Document status: *Draft for internship review — authorization pending.*